

CAPÍTULO 8 – PARTE I

SEGURIDAD INFORMÁTICA

ASIR · Administración de Sistemas Informáticos en Red

IES Aljada – Puente Tocinos (Murcia)

FWH

Fundamentos del Hardware
1.º curso

0. Introducción

La seguridad informática es el conjunto de medidas, procedimientos y controles técnicos y organizativos orientados a proteger la confidencialidad, integridad y disponibilidad (**tríada CIA**) de los sistemas de información y los datos que albergan.

En el contexto actual, el técnico de sistemas no solo debe conocer la administración de equipos y redes, sino también actuar como primera línea de defensa ante las amenazas cibernéticas. Según el informe ENISA Threat Landscape 2024, el ransomware, el phishing y los ataques a la cadena de suministro siguen siendo las tres amenazas más críticas para organizaciones europeas.

Tríada CIA – Concepto clave de seguridad

- Confidencialidad: Solo los usuarios autorizados pueden acceder a la información.
- Integridad: La información no ha sido alterada de forma no autorizada.
- Disponibilidad: Los sistemas y datos están accesibles cuando se necesitan.

En este capítulo se estudian los tipos de amenazas (malware, ataques de red e ingeniería social), los procedimientos y políticas de seguridad, la protección física y lógica de equipos y datos, la seguridad inalámbrica y el proceso de resolución de problemas de seguridad.

1. Amenazas a la Seguridad

1.1 Malware

El malware (del inglés malicious software) es todo software diseñado con fines maliciosos: destruir datos, robar información, extorsionar al usuario o permitir el control remoto de un equipo. Se instala habitualmente sin conocimiento del usuario, aprovechando vulnerabilidades del sistema o mediante ingeniería social.

¿Cómo llega el malware al equipo?

- Descarga de software gratuito no verificado o de fuentes no confiables.
- Apertura de adjuntos o enlaces maliciosos en correos electrónicos (phishing).
- Visita a sitios web comprometidos (drive-by download).
- Conexión de dispositivos USB encontrados en lugares públicos (baiting).
- Software sin actualizar: SO, navegadores o aplicaciones sin parches.
- Intercambio de archivos en redes P2P o sitios de torrents.
- Vulnerabilidades en aplicaciones web o protocolos de red.

1.1.1 Clasificación de Malware

La siguiente tabla recoge los tipos de malware más relevantes, incluyendo amenazas actualizadas a 2025:

Tipo de Malware	Descripción	Subtipos / Ejemplos
Virus	Requiere acción humana para propagarse. Se adjunta a archivos ejecutables o documentos. Puede destruir datos, corromper el sistema de arranque o robar información.	Boot sector, firmware, macro, programa, script
Troyano (Trojan)	Disfrazado de software legítimo. No se replica. Al ejecutarlo, instala puertas traseras, keyloggers, etc.	Acceso remoto, keylogger, destructivo, proxy, FTP, DoS
Ransomware	Cifra los archivos del usuario y exige rescate (normalmente en criptomonedas) para recuperarlos. Muy extendido en 2024-2025 (ej. LockBit, BlackCat).	Cifrado de archivos, cifrado de disco completo
Rootkit	Opera a nivel de kernel/administrador. Oculta su presencia modificando el SO, firewall y AV. Extremadamente difícil de eliminar sin reinstalar.	Firmware, kernel, hypervisor, bootloader
Spyware	Recopila información del usuario sin consentimiento: contraseñas, historial de navegación, datos bancarios.	Keylogger, adware espía, stalkerware
Adware	Muestra publicidad no deseada, redirige el navegador. Generalmente menos dañino, pero intrusivo.	Pop-ups, barras de herramientas falsas
Gusano (Worm)	Autorreplicante. No necesita acción humana. Se propaga por la red explotando vulnerabilidades.	WannaCry (2017), Mirai (IoT)
Fileless Malware	No deja archivos en disco. Reside en memoria RAM o registros del sistema. Muy difícil de detectar por AV convencionales. ★ Amenaza creciente 2024-2025.	Living-off-the-land (LOtL), PowerShell, WMI
Botnet / Zombie	Red de equipos infectados controlados remotamente. Usados para DDoS, spam, minería de criptomonedas o distribución de malware.	Mirai, Emotet, TrickBot

Nota didáctica: Sistemas Legacy y No Conformes

Un sistema legacy es aquel que ha dejado de recibir soporte del fabricante (ejemplo: Windows 7, Windows Server 2008). Un sistema no conforme es el que no ha aplicado los parches disponibles. Ambos representan el objetivo favorito del malware moderno, ya que sus vulnerabilidades son públicas y no hay solución oficial.

1.2 Prevención del Malware

1.2.1 Programas Antimalware

El software antimalware (comúnmente llamado antivirus, aunque su alcance es mucho mayor) constituye la primera línea de defensa activa del host. Funciona mediante dos mecanismos principales:

- Detección por firmas: Compara archivos contra una base de datos de firmas de malware conocido. Requiere actualizaciones frecuentes.
- Análisis heurístico y de comportamiento: Detecta patrones de conducta sospechosos aunque el malware sea desconocido. Clave frente a amenazas de día cero.
- Sandboxing: Ejecuta archivos sospechosos en un entorno aislado para analizar su comportamiento sin riesgo para el sistema real.

Fabricantes de referencia (2025): Microsoft Defender (integrado en Windows 10/11), ESET NOD32, Bitdefender, Kaspersky, Trend Micro, CrowdStrike Falcon (EDR).

Advertencia: Falsos Antivirus (Scareware)

Durante la navegación pueden aparecer ventanas emergentes que simulan ser alertas reales de Windows indicando que el equipo está infectado. Son malware en sí mismos (scareware). Ante una ventana sospechosa:

- Nunca hacer clic dentro de la ventana.
- Cerrar la pestaña o el navegador.
- Si no responde: Alt+F4 o Task Manager > Finalizar tarea.
- Escanear el equipo con el antimalware instalado.

1.2.2 Proceso de Eliminación de Malware (7 pasos)

Cuando se sospecha o confirma una infección, se debe seguir este procedimiento estandarizado:

1. Identificar e investigar los síntomas: lentitud inusual, procesos desconocidos, alertas del AV, conexiones de red no autorizadas.
2. Poner en cuarentena el sistema infectado: desconectar de la red (cable y WiFi) para evitar propagación.
3. Deshabilitar la Restauración del Sistema en Windows (los puntos de restauración pueden contener archivos infectados).
4. Corregir los sistemas infectados: ejecutar el AV en modo seguro (Safe Mode), usar herramientas especializadas del fabricante si es necesario.
5. Programar análisis periódicos y actualizar el AV y el SO.
6. Volver a habilitar la Restauración del Sistema y crear un nuevo punto de restauración limpio.
7. Educar al usuario final: explicar cómo ocurrió la infección y cómo prevenirla en el futuro.

Consejo práctico: Modo Seguro en Windows

Para acceder al modo seguro en Windows 10/11: Inicio > Configuración > Sistema > Recuperación > Inicio avanzado > Solucionar problemas > Opciones avanzadas > Configuración de inicio > Reiniciar > F4 (Modo seguro). En modo seguro se cargan solo los controladores esenciales, lo que impide que la mayoría del malware se ejecute.

1.2.3 Actualización de Firmas Antimalware

Las firmas de malware deben actualizarse regularmente ya que cada día se descubren miles de nuevas muestras. El proceso manual (si la actualización automática falla) es:

8. Crear un punto de restauración de Windows antes de la actualización.
9. Abrir el programa antimalware y desactivar temporalmente las actualizaciones automáticas.
10. Hacer clic en 'Actualizar' y descargar desde el sitio oficial del fabricante (o espejo oficial).
11. Ejecutar un análisis completo del sistema una vez actualizado.
12. Reactivar las actualizaciones automáticas y programar análisis periódicos.

Precaución: Espejos de Descarga

Algunos fabricantes usan servidores espejo (mirrors) para distribuir la carga. Asegúrese siempre de que el enlace al espejo provenga del sitio oficial del fabricante. Un espejo falso puede distribuir malware disfrazado de actualización.

1.3 Ataques de Red

1.3.1 Las Redes como Objetivo

Las redes son objetivos atractivos porque concentran una gran cantidad de recursos: servidores, bases de datos, sistemas de producción y comunicaciones. Un atacante típicamente sigue esta metodología de reconocimiento antes de lanzar un ataque:

- Recopilación de información (Footprinting): búsqueda en Google, WHOIS, Shodan, redes sociales corporativas, LinkedIn.
- Barrido de ping (Ping Sweep): determina qué IPs están activas en el rango objetivo.
- Escaneo de puertos: identifica servicios activos (herramientas: Nmap, Masscan).
- Análisis de vulnerabilidades: detecta versiones de SO y aplicaciones con fallos conocidos (herramientas: Nessus, OpenVAS, Nikto).
- Explotación: lanza exploits contra los servicios vulnerables (herramientas: Metasploit, Core Impact).

1.3.2 Tipos de Ataques TCP/IP

La siguiente tabla describe los principales ataques sobre la pila TCP/IP, incluyendo nuevas amenazas relevantes en 2025:

Tipo de Ataque	Descripción	Objetivo / Efecto
DoS (Denial of Service)	El atacante satura un servicio con peticiones falsas hasta dejarlo inoperativo.	Agotar recursos del servidor objetivo
DDoS (Distributed DoS)	DoS amplificado con miles de zombies (botnet). Extremadamente difícil de mitigar.	Sobrecarga masiva, anonimato del atacante
SYN Flood	Explota el handshake TCP: envía SYN masivos sin completar la conexión, agotando la tabla de estados.	Llenar la tabla de conexiones semabiertas
Envenenamiento DNS	Falsifica registros DNS para redirigir tráfico legítimo a servidores maliciosos.	MITM, robo de credenciales

Tipo de Ataque	Descripción	Objetivo / Efecto
MITM (Man-in-the-Middle)	Intercepta comunicaciones entre dos hosts. Puede usar ARP Poisoning o HTTPS Spoofing.	Captura y manipulación de tráfico
Spoofing	Suplantación de dirección IP, MAC o identidad para obtener acceso no autorizado.	Eludir controles basados en IP/MAC
Replay Attack	Captura y reenvía paquetes autenticados para hacerse pasar por el usuario legítimo.	Eludir autenticación
Ataque de Día Cero (0-day)	Explota vulnerabilidades desconocidas antes de que el fabricante publique parche.	Máxima peligrosidad por ausencia de defensa
Evil Twin / Rogue AP	Punto de acceso WiFi falso que imita a uno legítimo para capturar tráfico. ★ Creciente en 2025.	Robo de credenciales WiFi, MITM inalámbrico
Ataque de fuerza bruta	Prueba sistemática de contraseñas hasta encontrar la correcta. Automatizado con herramientas como Hydra o Hashcat.	Acceso no autorizado a sistemas y cuentas

1.3.3 Ataques de Día Cero (Zero-Day)

Un ataque de día cero explota una vulnerabilidad que aún no ha sido publicada ni parcheada por el fabricante. La terminología es la siguiente:

- Día cero (Day 0): momento en que el fabricante descubre la vulnerabilidad.
- Hora cero (Zero hour): momento en que se descubre la vulnerabilidad o se produce el primer ataque.
- Ventana de exposición: período entre el descubrimiento y la publicación del parche, durante el que la red es vulnerable.

Ejemplo real: Log4Shell (CVE-2021-44228)

En diciembre de 2021 se descubrió una vulnerabilidad crítica (CVSS 10/10) en la librería Log4j, usada por millones de aplicaciones Java. Durante los primeros días (ventana de exposición), se registraron más de 100 millones de intentos de explotación. Afectó a empresas como Apple, Amazon, Tesla y sistemas industriales. Ilustra perfectamente el impacto de un 0-day masivo.

1.3.4 Estrategia de Defensa en Profundidad

No existe una solución única contra todos los ataques. La estrategia recomendada es la Defensa en Profundidad (Defense in Depth), que combina múltiples capas de seguridad:

- VPN: cifra las comunicaciones de usuarios remotos y enlaza sedes.
- Firewall de perímetro (ASA/UTM): filtra tráfico entrante y saliente con inspección de estado (stateful).
- IDS/IPS: detecta y previene intrusiones en tiempo real analizando el tráfico.
- Servidor AAA (Authentication, Authorization, Accounting): controla quién accede a qué y registra las acciones.
- ESA (Email Security Appliance): filtra spam, phishing y adjuntos maliciosos.
- WSA (Web Security Appliance): bloquea el acceso a sitios maliciosos o no permitidos por política.

- SIEM (Security Information and Event Management): correlaciona eventos de seguridad de todos los dispositivos para detectar patrones de ataque. Herramientas: Splunk, IBM QRadar, Elastic SIEM.
- EDR (Endpoint Detection and Response): solución avanzada para endpoints que va más allá del antivirus tradicional. Herramientas: CrowdStrike, SentinelOne, Microsoft Defender for Endpoint.

Concepto clave: El modelo Zero Trust (2025)

El modelo de seguridad Zero Trust ("Nunca confíes, siempre verifica") ha sustituido al enfoque perimetral tradicional. En Zero Trust, ningún usuario ni dispositivo es de confianza por defecto, aunque esté dentro de la red corporativa. Se basa en:

- Verificación explícita de identidad en cada acceso (MFA obligatorio).
- Acceso de mínimo privilegio (Principle of Least Privilege).
- Asunción de brecha: el sistema se diseña asumiendo que puede ser comprometido.

1.4 Ingeniería Social

1.4.1 Concepto y Relevancia

La ingeniería social es el conjunto de técnicas de manipulación psicológica que explotan el comportamiento humano para obtener información confidencial o acceso no autorizado a sistemas. Se considera el eslabón más débil de la cadena de seguridad, ya que apunta a las personas y no a la tecnología.

Los atacantes se aprovechan de principios psicológicos como: urgencia, autoridad, miedo, reciprocidad, escasez y simpatía. La ingeniería social frecuentemente se combina con ataques técnicos para maximizar su efectividad.

1.4.2 Técnicas de Ingeniería Social

Técnica	Descripción	Contramedida
Phishing	Correo fraudulento imitando a entidades legítimas (bancos, Microsoft, Correos...)	Nunca hacer clic en enlaces de correos no solicitados
Spear Phishing	Phishing dirigido a un individuo u organización concretos, con información personalizada	Verificar remitente por canal alternativo
Smishing	Phishing por SMS. Muy frecuente en España (suplantación de Correos, BBVA, etc.)	Nunca introducir datos por SMS
Vishing	Phishing por llamada telefónica. El atacante se hace pasar por soporte técnico o banco	Cortar y llamar al número oficial
Pretexting	El atacante inventa un escenario creíble para obtener información (ej. técnico de IT ficticio)	Verificar identidad antes de dar información
Baiting (Cebo)	Se deja un USB infectado en un lugar público esperando que la víctima lo conecte	Nunca conectar dispositivos desconocidos
Tailgating / Piggybacking	Acceso físico no autorizado siguiendo a un empleado legítimo a zona restringida	Tarjetas de acceso individuales + concienciación

Técnica	Descripción	Contramedida
Quid pro quo	Ofrece algo (regalo, soporte técnico gratuito) a cambio de información o acceso	Desconfiar de ofrecimientos no solicitados
Shoulder Surfing	Observar discretamente la pantalla o teclado de la víctima	Filtros de privacidad en pantallas, concienciación
Dumpster Diving	Buscar documentos confidenciales en la basura sin destruir	Usar trituradoras de papel (nivel P-4 mínimo)

1.4.3 Protección contra la Ingeniería Social

La defensa más eficaz es la concienciación y formación continua de los usuarios. Las organizaciones deben implementar:

- Programas de formación y concienciación en ciberseguridad (Security Awareness Training).
- Simulaciones de phishing periódicas para medir y mejorar la respuesta de los empleados.
- Procedimientos claros de verificación de identidad (nunca dar contraseñas por teléfono o email).
- Política de "no confíes, verifica": ante cualquier solicitud inusual, confirmar por canal alternativo.
- Destrucción segura de documentos físicos (trituradora de papel, nivel P-4 o superior según DIN 66399).
- Control de acceso físico riguroso (tarjetas de acceso, mantrap, cámaras).

Ejemplo práctico: Simulación de Phishing

Herramientas como GoPhish o KnowBe4 permiten al departamento de IT enviar correos de phishing simulados a los empleados para medir su grado de vulnerabilidad. Los usuarios que caen en la trampa reciben formación inmediata. Esta es la forma más efectiva de elevar el nivel de concienciación.

2. Procedimientos de Seguridad

2.1 Política de Seguridad

2.1.1 ¿Qué es una Política de Seguridad?

Una política de seguridad es un documento formal que establece los objetivos, normas y procedimientos que una organización debe seguir para proteger sus activos de información. Es un documento vivo, que debe revisarse y actualizarse periódicamente para adaptarse a los cambios tecnológicos, organizativos y normativos.

En España y la UE, las organizaciones deben cumplir además con el Reglamento General de Protección de Datos (RGPD/GDPR) y, si son Administraciones Públicas, con el Esquema Nacional de Seguridad (ENS, Real Decreto 311/2022).

¿Qué debe responder una política de seguridad?

- ¿Qué activos necesitan protección?
- ¿Cuáles son las amenazas posibles?
- ¿Qué hacer en caso de incidente de seguridad?
- ¿Qué formación recibirán los usuarios?

- ¿Cómo acceden los usuarios remotos?
- ¿Cuáles son los usos aceptables de los recursos?

2.1.2 Categorías de la Política de Seguridad

- Política de identificación y autenticación: define quién puede acceder y cómo se verifica su identidad.
- Política de contraseñas: requisitos mínimos (longitud, complejidad, caducidad, historial).
- Política de uso aceptable (AUP): qué se puede y qué no se puede hacer con los recursos de la organización.
- Política de acceso remoto: VPN, autenticación multifactor (MFA), dispositivos permitidos.
- Política de mantenimiento de la red: gestión de parches, actualizaciones, ciclo de vida de los equipos.
- Política de gestión de incidentes: procedimiento de notificación, contención, erradicación y recuperación.
- Política de clasificación de la información: pública, interna, confidencial, secreta.
- Política de copias de seguridad: frecuencia, retención, verificación, almacenamiento externo.

2.2 Protección de Equipos Físicos

2.2.1 Seguridad Física

La seguridad física protege los activos tangibles de una organización: instalaciones, hardware, infraestructura de red y medios de almacenamiento. Un equipo robado implica también el robo o la pérdida de los datos que contiene.

Los niveles de seguridad física incluyen:

- Seguridad perimetral: vallas, barreras, control de acceso al edificio, guardas de seguridad.
- Control de acceso a áreas restringidas: tarjetas inteligentes, RFID, biometría.
- Videovigilancia: cámaras con detección de movimiento y grabación.
- Protección de hardware de red: salas de servidores cerradas con llave, racks con cerradura.

2.2.2 Tipos de Mecanismos de Bloqueo

Tipo de Bloqueo	Descripción	Nivel de Seguridad
Cerradura convencional	Llave física mecánica en la manija o cerrojo.	Bajo
Cerradura de cerrojo (deadbolt)	Llave en cerradura separada de la manija. Más resistente al forzado.	Medio
Cerradura electrónica (keypad)	Código PIN o combinación numérica. Sin llave física.	Medio
Tarjeta/Token (Smart Card)	Deslizar o aproximar tarjeta inteligente o llavero RFID.	Medio-Alto
Biométrica	Huella dactilar, reconocimiento facial, retina o voz. Sin elementos físicos que perder.	Alto

Tipo de Bloqueo	Descripción	Nivel de Seguridad
Multifactor (MFA física)	Combinación de dos o más mecanismos (ej.: PIN + huella). Máxima seguridad.	Muy Alto

2.2.3 Trampas de Seguridad (Mantrap)

Un mantrap (trampa de seguridad o esclusa de personal) es una sala de doble puerta utilizada en entornos de alta seguridad (centros de datos, salas de servidores). La primera puerta debe cerrarse completamente antes de que se abra la segunda, impidiendo el tailgating (acceso no autorizado siguiendo a una persona autorizada).

Ejemplo real: CPD (Centro de Procesamiento de Datos)

En un CPD de nivel Tier III o Tier IV, el mantrap es obligatorio. El visitante se identifica en la primera puerta (tarjeta + PIN). Una vez dentro, la puerta se cierra y un operador verifica la identidad mediante cámara antes de abrir la segunda puerta. Algunos sistemas incluyen báscula para detectar si hay más de una persona.

2.2.4 Protección de la Infraestructura de Red

- Todo el cableado debe discurrir por canaletas o estar embutido en paredes para evitar manipulación.
- Los armarios de comunicaciones (racks) deben estar en salas cerradas con llave.
- Los puertos de switch no utilizados deben desactivarse mediante software de gestión.
- Usar cámaras de seguridad con detección de movimiento y alarmas físicas.
- Etiquetar los equipos con sensores RFID para control de inventario y antirrobo.
- Los servidores portátiles o equipos en zonas públicas deben usar cables de seguridad Kensington.
- Los puertos USB no utilizados pueden sellarse físicamente con bloqueos USB.

2.3 Protección de Datos

2.3.1 Los Datos: El Activo más Valioso

Los datos son el activo más valioso de cualquier organización. Su pérdida puede tener consecuencias devastadoras: daño reputacional, pérdida de clientes, sanciones legales (hasta el 4% de la facturación anual global según el RGPD), ventaja competitiva comprometida y elevados costes de recuperación.

La Prevención de Pérdida de Datos (DLP – Data Loss Prevention) es el conjunto de herramientas y procedimientos para evitar que información sensible salga de la organización sin autorización. Las soluciones DLP monitorizan canales como email, USB, impresión y nube.

2.3.2 Copias de Seguridad (Backup)

El backup es la medida de protección de datos más fundamental y eficaz. Debe estar recogida en la política de seguridad con criterios claros de frecuencia, retención, almacenamiento y pruebas de restauración.

Tipo	¿Qué copia?	Espacio	Restauración	Frecuencia	Notas
Completa (Full)	Copia de todos los datos	Alta	Bajo	Semanal o mensual	Base para recuperación completa

Tipo	¿Qué copia?	Espacio	Restauración	Frecuencia	Notas
Incremental	Solo los cambios desde el último backup (full o incremental)	Baja	Alto (necesita toda la cadena)	Diaria	Rápida de hacer, lenta de restaurar
Diferencial	Cambios desde el último backup completo	Media	Medio	Diaria / semanal	Equilibrio entre espacio y velocidad de restauración
Snapshot	Imagen del estado del sistema en un instante (muy usado en VMS)	Variable	Muy bajo	Bajo demanda	Ideal en entornos virtualizados (VMware, Hyper-V)

Regla 3-2-1 del Backup

- 3 copias de los datos (1 original + 2 backups).
- 2 tipos de medios de almacenamiento diferentes (ej.: disco duro externo + cinta o NAS).
- 1 copia fuera de las instalaciones (offsite) o en la nube. Protege frente a desastres físicos.

En 2025 se recomienda ampliarla a la regla 3-2-1-1-0: 1 copia offline (air-gapped) y 0 errores verificados en restauración.

2.3.3 Permisos de Archivos y Carpetas (NTFS)

El sistema de permisos NTFS de Windows permite controlar con granularidad el acceso a archivos y carpetas para usuarios y grupos. El principio fundamental es el Mínimo Privilegio: cada usuario accede solo a los recursos que necesita para realizar su trabajo.

Permiso NTFS	Ver contenido	Modificar archivos	Crear archivos	Ejecutar	Eliminar
Control total	✓	✓	✓	✓	✓
Modificar	✓	✓	✓	✓	x
Leer y ejecutar	✓	x	✓	✓	x
Leer	✓	x	x	x	x
Escribir	x	✓	✓	x	✓

Para configurar permisos NTFS: clic derecho en archivo/carpetas > Propiedades > Seguridad > Editar.

Propagación de permisos: comportamiento en copias y movimientos

- Mover al mismo volumen: conserva los permisos originales.
- Copiar en el mismo volumen: hereda permisos del destino.
- Mover a volumen diferente: hereda permisos del destino.
- Copiar a volumen diferente: hereda permisos del destino.

2.3.4 Cifrado de Archivos y Carpetas (EFS)

El Sistema de Cifrado de Archivos (EFS – Encrypting File System) es una característica de Windows (Pro, Enterprise, Education) que cifra archivos y carpetas a nivel de volumen NTFS. El cifrado está vinculado a la cuenta de usuario: solo el usuario que cifró los datos puede descifrarlos.

Procedimiento para cifrar con EFS:

13. Seleccionar el archivo o carpeta.
14. Clic derecho > Propiedades > Avanzado.
15. Marcar «Cifrar contenido para proteger datos» > Aceptar.
16. Los archivos cifrados con EFS aparecen en color verde en el Explorador de archivos.

EFS vs. BitLocker: ¿Cuál usar?

- EFS: Cifrado a nivel de archivo/carpeta. Transparente para el usuario. Vinculado a su cuenta. Útil para proteger archivos concretos.
- BitLocker: Cifrado del disco completo (o volumen). Protege todos los datos, incluidos los archivos de sistema. Requiere TPM (recomendado). Más adecuado para portátiles que pueden ser robados.
- Recomendación 2025: usar BitLocker para el disco del sistema + EFS para carpetas de datos especialmente sensibles.

2.3.5 BitLocker y BitLocker To Go

BitLocker es la solución de cifrado de disco completo de Windows, disponible en ediciones Pro, Enterprise y Education (Windows 10 y 11). Cifra todo el volumen del sistema operativo, haciendo que los datos sean ilegibles si el disco se extrae del equipo.

Requisito previo: el equipo debe disponer de un chip TPM (Trusted Platform Module) versión 1.2 o superior. El TPM almacena las claves de cifrado y garantiza la integridad del proceso de arranque.

Activación de BitLocker en Windows 10/11:

17. Panel de control > Cifrado de unidad BitLocker.
18. Clic en «Activar BitLocker» en el volumen del sistema operativo.
19. Si el TPM no está inicializado, el asistente guía su configuración desde el BIOS/UEFI.
20. Guardar la clave de recuperación (en cuenta Microsoft, USB, red o impresa).
21. Seleccionar «Cifrar solo el espacio usado» (instalaciones nuevas) o «Cifrar unidad completa» (equipos en uso).
22. Activar comprobación del sistema BitLocker > Continuar > Reiniciar.

BitLocker To Go extiende el cifrado a unidades extraíbles (USB, discos externos). No requiere TPM; usa contraseña o tarjeta inteligente. Imprescindible para cualquier organización que use memorias USB con datos sensibles.

Ejemplo práctico: BitLocker en portátiles corporativos

En una empresa con 50 portátiles, si se pierde uno sin BitLocker, todos sus datos (correos, documentos, contraseñas en caché) están expuestos. Con BitLocker activo, sin la contraseña o la clave de recuperación, el disco es ilegible. El RGPD considera el cifrado como una medida técnica adecuada que puede evitar la obligación de notificar una brecha de seguridad a la AEPD.

2.4 Destrucción Segura de Datos

2.4.1 ¿Por qué no basta con «Eliminar»?

Cuando se elimina un archivo en Windows, el sistema operativo solo borra la referencia en la tabla de asignación de archivos (MFT en NTFS), pero los datos físicos permanecen en el disco hasta ser sobrescritos. Herramientas de recuperación forense como Recuva, Autopsy o EnCase pueden recuperar estos datos con facilidad.

Por este motivo, antes de reutilizar, vender o desechar cualquier medio de almacenamiento, los datos deben destruirse de forma segura e irreversible.

2.4.2 Métodos de Borrado Seguro

Método	Tipo de Medio	Descripción	Seguridad
Software de borrado seguro	HDD	Sobrescribe sectores con patrones aleatorios múltiples veces (1, 3, 7 o 35 pasadas según DoD 5220.22-M). Ej.: DBAN, Eraser, Blancco.	Alta (HDD)
Desmagnetización (Degaussing)	HDD, cintas magnéticas	Imán muy potente que destruye el campo magnético. Varita manual (2 min por disco) o dispositivo electromagnético (segundos). Inutiliza el disco.	Muy alta
Borrado seguro SSD	SSD, eMMC, USB flash	Usa el comando ATA Secure Erase o herramientas del fabricante (Samsung Magician, Crucial SSD Dashboard). El cifrado previo + borrado de clave también es efectivo.	Alta (si se hace correctamente)
Destrucción física	Todos	Trituradoras de discos (shredder), desintegradoras, incineración. Para grandes volúmenes, contratar empresa certificada (certificado de destrucción).	Absoluta
Cifrado + borrado	SSD, eMMC, USB	Cifrar el dispositivo con BitLocker o similar antes de borrarlo. Incluso si queda rastro de datos, son ilegibles sin la clave.	Muy alta

Atención: SSD y técnicas magnéticas

Las técnicas de desmagnetización (degaussing) son INEFICACES en unidades SSD, eMMC y memorias flash, ya que no almacenan datos mediante campos magnéticos. Para estos medios, usar borrado seguro por software (ATA Secure Erase) o destrucción física.

2.4.3 Reciclaje y Destrucción de Discos

Cuando un medio de almacenamiento ya no es necesario, existen dos opciones:

- **Reciclaje:** El disco se borra de forma segura (software o degaussing) y puede reutilizarse. Se realiza un formato de bajo nivel (marcado de sectores en fábrica) y posteriormente un formato estándar (sistema de archivos).
- **Destrucción:** Para datos altamente sensibles, se destruye físicamente el dispositivo. Las empresas especializadas en destrucción de medios emiten un Certificado de Destrucción que acredita el proceso (obligatorio en muchos sectores por normativa).

Dispositivos que almacenan datos y se pasan por alto

- Impresoras y MFPs: suelen tener disco duro interno con caché de documentos.
- Routers y switches: guardan configuraciones con contraseñas.
- Smartphones y tablets corporativos: contactos, correos, VPN, apps de empresa.
- Fotocopiadoras: almacenan imagen de cada documento copiado.
- Todos estos deben incluirse en la política de destrucción segura de datos.

3. Seguridad en la Estación de Trabajo

3.1 Protección del Equipo

3.1.1 Protección de la BIOS/UEFI

La BIOS/UEFI es el primer software que se ejecuta al arrancar un equipo. Si está comprometida, toda la seguridad del sistema operativo puede ser ineficaz. Medidas de protección:

- Establecer contraseña de administrador en la BIOS/UEFI para evitar cambios no autorizados en la configuración.
- Configurar el orden de arranque para que el disco duro del SO sea el primero. Impide arrancar desde medios externos no autorizados.
- Activar Secure Boot (arranque seguro): solo permite cargar cargadores de arranque firmados digitalmente. Protege contra bootkits y rootkits de firmware.
- Activar TPM 2.0: necesario para BitLocker, Windows Hello y otras funciones de seguridad en Windows 11.
- Deshabilitar puertos no utilizados desde la BIOS: USB, FireWire, Thunderbolt, etc.

3.1.2 Gestión de Contraseñas

Las contraseñas son la principal barrera de acceso a los sistemas. Una mala política de contraseñas es una de las causas más frecuentes de brechas de seguridad.

Buenas prácticas de contraseñas (NIST SP 800-63B, 2024)

- Longitud mínima de 12 caracteres (NIST recomienda priorizar longitud sobre complejidad).
- Usar frases de contraseña (passphrase) en lugar de contraseñas complejas difíciles de recordar.
- No reutilizar contraseñas. Usar un gestor de contraseñas (Bitwarden, KeePass, 1Password).
- Activar autenticación multifactor (MFA) en todos los servicios críticos.
- No exigir caducidad periódica salvo que exista evidencia de compromiso (cambio NIST 2020).
- Comparar contraseñas contra listas de contraseñas comprometidas conocidas (HaveIBeenPwned).

3.2 Política de Seguridad Local de Windows

La Política de Seguridad Local (secpol.msc) permite configurar en un equipo Windows parámetros de seguridad sin necesidad de un dominio Active Directory. Incluye:

- Políticas de cuenta: complejidad y longitud mínima de contraseña, historial, duración, bloqueo de cuenta.
- Políticas locales: auditoría de eventos, asignación de derechos de usuario, opciones de seguridad.
- Firewall de Windows con seguridad avanzada.
- Políticas de software de restricción (SRP) y AppLocker.

Acceso a herramientas de seguridad en Windows

- secpol.msc – Política de seguridad local
- lusrmgr.msc – Administrador de usuarios y grupos locales
- gpedit.msc – Editor de directiva de grupo local
- eventvwr.msc – Visor de eventos (auditoría)
- wf.msc – Firewall de Windows con seguridad avanzada

3.3 Gestión de Usuarios y Grupos

En Windows, la gestión de usuarios y grupos locales se realiza desde: Panel de control > Herramientas administrativas > Administración del equipo > Usuarios y grupos locales (o lusrmgr.msc).

Grupos predefinidos relevantes:

- Administradores: acceso total al equipo. Usar con precaución, siguiendo el principio de mínimo privilegio.
- Usuarios estándar: acceso limitado. No pueden instalar software ni modificar configuraciones del sistema.
- Invitados: acceso muy restringido. Desactivado por defecto en Windows 10/11.
- Operadores de copia de seguridad: pueden realizar copias de seguridad sin ser administradores.

Principio de mínimo privilegio (PoLP)

Cada usuario, proceso o sistema solo debe tener los permisos mínimos necesarios para realizar su función. Esto limita el daño en caso de compromiso de una cuenta o ejecución de malware con los permisos de esa cuenta. Es un pilar fundamental de la seguridad por capas.

3.4 Firewall de Windows

3.4.1 Conceptos: Cortafuegos y Zonas de Red

Un cortafuegos (firewall) es un sistema (hardware, software o combinación de ambos) que controla el tráfico de red entrante y saliente basándose en un conjunto de reglas predefinidas. Clasifica y filtra el tráfico para permitir o denegar conexiones.

Zonas de red típicas:

- LAN (Local Area Network): red interna de confianza.
- WAN (Wide Area Network / Internet): red externa, no confiable.

- DMZ (Zona Desmilitarizada): zona semi-aislada donde se ubican servidores públicos (web, correo, DNS). Accesible desde Internet pero aislada de la LAN interna.

3.4.2 Firewall de Windows Defender

Windows incluye un firewall basado en host desde Windows XP SP2. En Windows 10/11 se denomina «Firewall de Windows Defender» y ofrece dos niveles de configuración:

- Interfaz básica (Panel de control > Firewall de Windows Defender): activar/desactivar, reglas de aplicaciones, notificaciones.
- Interfaz avanzada (wf.msc): reglas de entrada y salida por protocolo, puerto, programa o dirección IP; supervisión de conexiones activas; perfiles de red (Dominio, Privado, Público).

Ejemplo: Abrir el puerto 80 (HTTP) en el Firewall de Windows

- Abrir wf.msc (Firewall de Windows con seguridad avanzada).
- Reglas de entrada > Nueva regla.
- Tipo: Puerto > TCP > Puerto específico: 80.
- Acción: Permitir la conexión.
- Perfil: seleccionar según necesidad (Dominio/Privado/Público).
- Nombre: HTTP entrante.

3.5 Seguridad Web

El navegador web es una de las superficies de ataque más grandes de un usuario. Las medidas de seguridad incluyen:

- Mantener el navegador actualizado: instalar actualizaciones de seguridad tan pronto como se publiquen.
- Gestionar extensiones/complementos: instalar solo desde fuentes oficiales y revisar los permisos solicitados. Eliminar las no utilizadas.
- Verificar certificados HTTPS (TLS): comprobar que el sitio usa HTTPS y que el certificado es válido (candado en la barra de direcciones).
- Configurar privacidad: deshabilitar cookies de terceros, activar la protección contra seguimiento.
- Usar modo InPrivate/Incógnito: no guarda historial ni cookies. Útil en equipos compartidos.
- Bloqueador de ventanas emergentes (pop-ups): habilitado por defecto en navegadores modernos.
- Filtro SmartScreen (Edge/IE): bloquea sitios de phishing y descargas maliciosas conocidas.
- Usar un gestor de contraseñas integrado o de terceros para evitar reutilización de contraseñas.

Indicadores de sitio seguro (2025)

- HTTPS + candado en la barra de direcciones.
- Certificado válido: no expirado, emitido por CA de confianza, nombre coincide con el dominio.
- Atención: HTTPS solo garantiza cifrado del canal, NO que el sitio sea legítimo. Los sitios de phishing también usan HTTPS.

3.6 Mantenimiento de Seguridad

- Configuración restrictiva por defecto: deshabilitar servicios y protocolos innecesarios (principio de superficie mínima de ataque).
- Deshabilitar la reproducción automática (AutoRun/AutoPlay): evita la ejecución automática de malware desde USB u otros medios extraíbles.
- Gestión de parches: aplicar actualizaciones del SO y aplicaciones de forma regular. En entornos corporativos, usar herramientas como WSUS (Windows Server Update Services) o SCCM/Intune.
- Auditoría de cuentas: revisar periódicamente usuarios, grupos y permisos para eliminar cuentas obsoletas.
- Copias de seguridad verificadas: no basta con hacer backup; hay que probar la restauración periódicamente.

4. Seguridad Inalámbrica

4.1 Protocolos de Cifrado WiFi

Las redes inalámbricas presentan un vector de ataque adicional respecto a las redes cableadas: cualquier dispositivo dentro del rango de la señal puede intentar conectarse. Por ello, el cifrado y la autenticación son críticos.

Protocolo	Cifrado	Análisis de seguridad	Estado 2025
WEP (1997)	RC4 40-64 bits	Muy débil. Roto en minutos con herramientas como aircrack-ng. OBSOLETO.	✗ Nunca usar
WPA (2003)	RC4 + TKIP	Mejora WEP pero usa el mismo RC4. Vulnerable a ataques de diccionario.	✗ Obsoleto
WPA2-Personal (2004)	AES-CCMP	Estándar actual mínimo. Vulnerable a ataques de diccionario offline si la PSK es débil.	⚠ Aceptable con PSK robusta
WPA2-Enterprise	AES-CCMP + 802.1X/RADIUS	Autenticación individual por usuario. Ideal para entornos corporativos.	✓ Recomendado empresas
WPA3-Personal (2018)	SAE (reemplaza PSK)	Protección contra ataques de diccionario offline. Obligatorio en nuevos routers certificados WiFi 6.	✓✓ Recomendado doméstico
WPA3-Enterprise (2018)	AES-256 + CNSA Suite	Nivel de seguridad gubernamental/militar. Requiere infraestructura compatible.	✓✓ Máxima seguridad

⚠ Ataques específicos a redes WiFi (2025)

- KRACK (Key Reinstallation Attack): afecta a WPA2. Mitigado con parches en sistemas actualizados.
- PMKID Attack: permite capturar el handshake WPA2 sin conectarse a la red. Uso de diccionarios offline.
- Evil Twin: punto de acceso falso que imita al legítimo. Usar VPN en redes WiFi públicas.
- Deauthentication Attack: desconecta forzosamente dispositivos de la red WiFi para capturar el handshake de reconexión.

4.2 Mejores Prácticas de Configuración WiFi

- Usar WPA3 (o WPA2-AES como mínimo). Nunca WEP ni WPA-TKIP.
- Cambiar el SSID y contraseña por defecto del router. Usar una contraseña robusta (mínimo 20 caracteres aleatorios).
- Desactivar WPS (WiFi Protected Setup): vulnerable a ataques de fuerza bruta de PIN.
- Ocultar el SSID (no difundir el nombre de la red): medida de seguridad débil por sí sola, pero reduce la exposición ante atacantes oportunistas.
- Configurar filtrado MAC: solo se permite la conexión de dispositivos con MACs autorizadas. Seguridad débil (MACs se pueden suplantar), pero añade una capa más.
- Separar la red de invitados (Guest Network) de la red corporativa. Los invitados acceden a Internet pero no a los recursos internos.
- Actualizar el firmware del router regularmente para parchar vulnerabilidades.
- Desactivar la administración remota del router (si no es necesaria).
- Activar el firewall del router y configurar reglas de reenvío de puertos (port forwarding) solo para servicios necesarios.
- Deshabilitar UPnP (Universal Plug and Play) en entornos corporativos: puede abrir puertos de forma automática y no controlada.

4.3 Métodos de Autenticación WiFi

- PSK (Pre-Shared Key) / Clave personal: contraseña compartida entre todos los usuarios. Adecuada para uso doméstico. En WPA3 usa SAE (Simultaneous Authentication of Equals) que resiste ataques de diccionario offline.
- 802.1X / EAP (Extensible Authentication Protocol): autenticación por usuario mediante servidor RADIUS. Cada usuario tiene sus propias credenciales. Estándar para entornos empresariales (WPA2/WPA3 Enterprise).
- Certificados digitales: el servidor RADIUS autentica al cliente mediante certificado. Máxima seguridad, requiere infraestructura PKI.

5. Proceso de Resolución de Problemas de Seguridad

5.1 Los Seis Pasos Aplicados a la Seguridad

El proceso estándar de resolución de problemas de TI se aplica también a incidentes de seguridad:

1. Identificar el problema: Recopilar información del usuario, analizar síntomas (lentitud, alertas, comportamiento inusual), revisar logs del sistema y AV.
2. Establecer una teoría de causa probable: Basándose en los síntomas, plantear hipótesis (¿infección de malware? ¿ataque de red? ¿usuario comprometido?). Aplicar el principio de parsimonia (la explicación más simple suele ser correcta).
3. Probar la teoría: Ejecutar herramientas de diagnóstico (AV, análisis de red, revisión de procesos con Process Explorer), verificar logs de eventos.
4. Establecer plan de acción e implementar solución: Cuarentena del sistema, eliminación del malware, restauración desde backup, aplicación de parches, cambio de credenciales comprometidas.
5. Verificar funcionalidad y aplicar medidas preventivas: Confirmar que el sistema funciona correctamente, activar el AV y Restauración del Sistema, actualizar el SO y aplicaciones, revisar la política de seguridad.

6. Documentar hallazgos, acciones y resultados: Registrar todo el proceso en un ticket o informe de incidente. La documentación es clave para el análisis forense, el cumplimiento normativo y la mejora continua.

5.2 Problemas Comunes y Soluciones

Síntoma	Causa probable	Solución
El equipo va muy lento / alto uso de CPU sin motivo aparente	Malware (ransomware cifrando, cryptominer, botnet)	Modo seguro > Análisis completo AV > Eliminar o reinstalar
El navegador redirige a sitios extraños	Hijacker de navegador, adware, cambio de DNS	Restablecer configuración del navegador, revisar DNS, escanear con Malwarebytes
Aparecen ventanas emergentes de antivirus falso	Scareware, adware	Cerrar con Alt+F4 o Administrador de tareas. Escanear el equipo
El usuario no puede acceder a sus archivos (mensaje de rescate)	Ransomware	Aislar equipo, NO pagar. Restaurar desde backup limpio. Notificar al responsable de seguridad
Tráfico de red inusual o conexiones a IPs desconocidas	Malware con comunicación C2, botnet, spyware	Analizar tráfico con Wireshark, bloquear en firewall, aislar equipo
La cuenta de usuario está bloqueada repetidamente	Ataque de fuerza bruta, keylogger, compartición de credenciales	Revisar log de eventos, cambiar contraseña, activar MFA
Archivos del sistema modificados o faltantes	Virus, rootkit	Escanear con AV, usar SFC /scannow, considerar reinstalación del SO
El AV se desactiva solo o no puede actualizarse	Malware que deshabilita el AV (troiano desactivador de seguridad)	Arrancar desde medio externo limpio, usar herramienta de rescate del fabricante AV

6. Conclusión

La seguridad informática no es un estado estático que se alcanza, sino un proceso continuo de mejora y adaptación. Las amenazas evolucionan constantemente y los profesionales de sistemas deben mantenerse actualizados.

Los pilares fundamentales que debe dominar un Técnico Superior en ASIR son:

- Conocer las amenazas: malware, ataques de red e ingeniería social.
- Implementar una política de seguridad coherente con la organización y la normativa vigente (RGPD, ENS).
- Aplicar seguridad en capas (defensa en profundidad / Zero Trust): no depender de una única medida.
- Proteger los datos mediante cifrado, permisos adecuados y copias de seguridad verificadas.

- Gestionar correctamente usuarios, contraseñas y autenticación multifactor.
- Documentar todos los incidentes y mantener el conocimiento actualizado.

Referencias y recursos de actualización (2025)

- ENISA Threat Landscape 2024: enisa.europa.eu
- NIST Cybersecurity Framework 2.0: nist.gov/cyberframework
- CCN-CERT (Centro Criptológico Nacional): ccn-cert.cni.es
- INCIBE (Instituto Nacional de Ciberseguridad): incibe.es
- AEPD (Agencia Española de Protección de Datos): aepd.es
- Esquema Nacional de Seguridad – RD 311/2022: administracion.gob.es/ens
- Have I Been Pwned (verificar contraseñas comprometidas): haveibeenpwned.com